

ZIP已知明文攻击深入利用

👤 光通天下

🕒 2020-11-18 10:29:49

👤 605939

💬 7

一、前言

你加密的压缩包比你想象中的还不安全！

哪怕对于信息安全人员来说，很多时候给压缩包加上一个密码就以为的是万事大吉了。但事实是，很多情况下，你的加密压缩包，远远没有你想象的安全。

二、内容概要

以往进行ZIP已知明文攻击，通常需要一个完整的明文文件。而本文讨论的攻击方式只需要知道加密压缩包内容的12个字节，即可进行攻击破解降低了已知明文的攻击难度。同时，结合各类已知的文件格式，更拓宽了ZIP已知明文攻击的攻击面。

三、正文

3.1 ZIP已知明文攻击的一般利用

以往出现在网络安全竞赛中的已知明文攻击考点，或者大部分网上的文章，都需要知道加密zip文件中的一个完整明文文件并且要求明文以相同的标准被压缩，这才有可能攻击成功。

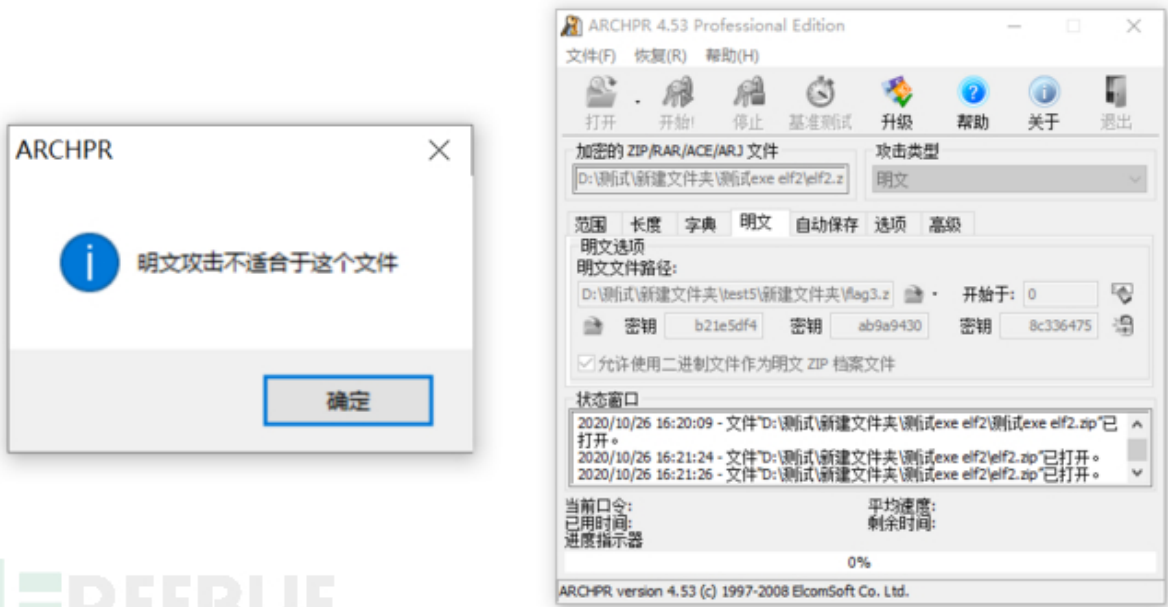
其实传统的已知明文攻击要成功需要三个条件，在此我将条件列出来：

- 完整的明文文件
- 明文文件需要被相同的压缩算法标准压缩（也可理解为被相同压缩工具压缩）
- 明文对应文件的加密算法需要是 ZipCrypto Store

第三点是我们实际应用中常常会被忽略的。因竞赛中遇到的题目，都是提前设置好的。

· AES256-Deflate/AES256-Store加密的文件不适用于明文攻击。

名称	算法	大小	压缩后大小	修改时间
1312.txt	AES-256 Deflate	4	34	2020-11-10 13:38
mingwen.txt	AES-256 Deflate	18	32	2020-11-10 13:39



ZIP的加密算法大致分为两种ZipCrypto和AES-256,各自又分Deflate和Store。

- ZipCrypto Deflate
- ZipCrypto Store
- AES-256 Deflate
- AES-256 Store

ZipCrypto算是传统的zip加密方式。只有使用ZipCrypto Deflate /Store才可以使用 ZIP已知明文攻击进行破解。

传统的ZIP已知明文攻击利用，windows下可以使用AZPR，linux下可以使用pkcrack。

3.2 ZIP已知明文攻击的深入利用

本文要探讨的攻击方法并不需要知道压缩文件中完整的明文，只需在已知加密压缩包中的少部分明文字节时即可进行攻击破解。而各类文件都有其自身固定的文件格式，结合这类格式，极大扩展了ZIP明文攻击的攻击面。

具体要求如下：

- 至少已知明文的12个字节及偏移，其中至少8字节需要连续。
- 明文对应的文件加密方式为ZipCrypto Store

该方法对于ZIP加密的算法有要求，明文对应的文件加密方式需要为ZipCrypto Store。经测试，Winrar（v5.80）、7zip（v19.00）默认状态下加密使用的就是AES256算法，直接排除。360压缩（v4.0.0.1220）、好压（v6.2）使用的是ZipCrypto，不固定使用Store或Deflate（如果要固定使用ZipCrypto Store算法加密，可以在压缩的时候指定压缩方式为“存储”）。

以下破解用到的压缩包，都是经360压缩或者好压加密打包的。

3.2.1 使用到的工具项目

bkcrack：https://github.com/kimci86/bkcrack



光通天下 LV.3

光通天下网络科技股份有限公司

关注

10
文章数

4
评论数

15
关注者

• 代码审计之旅-JtopCMS文件上传漏洞 (CNVD-2021-05471)

2021-03-29

• VBS远控病毒（二） | 攻击模拟与取证分析

2020-07-06

• DEDECMS伪随机漏洞分析（三）碰撞点

2020-07-05

浏览更多

文章目录

一、前言

二、内容概要

三、正文

3.1 ZIP已知明文攻击的一般...

3.2 ZIP已知明文攻击的深入...

3.3 实操案例

四、结尾

4.1 结语

4.2 注意点

4.3 附件下载

4.4 参考文章



make //在src下生成bkcrack文件
cp bkcrack /usr/sbin/bkcrack //作为系统命令使用

bkcrack常用参数：

- c 提取的密文部分
- p 提取的明文部分
- x 压缩包内目标文件的偏移地址 部分已知明文值
- C 加密压缩包
- o offset -p参数指定的明文在压缩包内目标文件的偏移量

在此我们不是“造轮子”，而是“使用轮子”，偏向于实操，利用已有的手段工具去解决现有的问题。话不多说，上实操案例。

3.3 实操案例

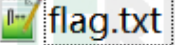
案例中演示的压缩包等，都可在文末附件中下载。

3.3.1 加密文本破解

文本类文件被加密成zip时，有很大的概率以ZipCrypto Store方式加密存储。

创建加密zip：

生成uuid，将字符串“flag{16e371fa-0555-47fc-b343-74f6754f6c01}”保存为flag.txt。然后用360压缩将文件添加为加密ZIP: flag_360.zip

名称	算法	大小	压缩后大小
 flag.txt	ZipCrypto Store	42	54

攻击破解：

采用8+4的方式提取部分已知明文来进行攻击测试，
flag{16e371fa-0555-47fc-b343-74f6754f6c01}

我们利用以下这部分明文，来进行攻击破解：

*lag{16e3*****74f6*****

#准备已知明文

echo -n "lag{16e3" > plain1.txt //连续的8明文
echo -n "74f6" | xxd //额外明文的十六进制格式，37346636

#攻击

bkcrack -C flag_360.zip -c flag.txt -p plain1.txt -o 1 -x 29 37346636

#由于时间较长，为防止终端终端导致破解中断，可以加点小技巧

bkcrack -C flag_360.zip -c flag.txt -p plain1.txt -o 1 -x 29 37346636 > 1.log& //后台运行，结果存入1.log

//加上time参数方便计算爆破时间

time bkcrack -C flag_360.zip -c flag.txt -p plain1.txt -o 1 -x 29 37346636 > 1.log&

//查看爆破进度

tail -f 1.log

注：· -p 指定的明文不需要转换，-x指定的明文需要转成十六进制
· 提到的偏移都是指“已知明文在加密前文件中的偏移”。

历时近16分钟，成功得到秘钥，这不是压缩包的加密密码，而是ZIP内部的三段秘钥。

```
root@labs-a3:~/blus/1027# time bkcrack -C flag_360.zip -c flag.txt -p plain1.txt -o 1 -x 29 37346636 > 1.log&
[1] 19625
root@labs-a3:~/blus/1027# tail -f 1.log
Generated 4194304 Z values.
[22:15:46] Attack on 4194304 Z values at index 8
39.3 % (1646785 / 4194304)
[22:31:43] Keys
b21e5df4 ab9a9430 8c336475

real    15m56.836s
user    380m38.762s
sys     0m29.351s
```

b21e5df4 ab9a9430 8c336475

使用该秘钥进行解密：

bkcrack -C flag_360.zip -c flag.txt -k b21e5df4 ab9a9430 8c336475 -d flag.txt

```
root@labs-a3:~/blus/1027# bkcrack -C flag_360.zip -c flag.txt -k b21e5df4 ab9a9430 8c336475 -d flag.txt
Wrote deciphered text.
root@labs-a3:~/blus/1027# cat flag.txt
flag{16e371fa-0555-47fc-b343-74f6754f6c01}root@labs-a3:~/blus/1027#
```

3.3.2 利用PNG图片文件头破解

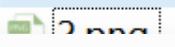
PNG文件头：

 PNG_header

Offset(h)	00	01	02	03	04	05	06	07	08	09	0A	0B	0C	0D	0E	0F
	00	00	00	00	89	50	4E	47	0D	0A	1A	0A	00	00	00	0D 49 48 44 52 %PNG.....IHDR

89 50 4E 47 0D 0A 1A 0A 00 00 00 0D 49 48 44 52

满足，12个字节的要求。拿一张图片和一个flag.txt一起打包成加密ZIP压缩包：png4.zip

名称	算法	大小	压缩后大小
 png4.zip	ZipCrypto Store	19 670	19 692

攻击破解：

#准备已知明文

echo 89504E470D0A1A0A0000000D49484452 | xxd -r -ps > png_header

#攻击

time bkrack -C png4.zip -c 2.png -p png_header -o 0 >1.log&

tail -f 1.log

耗时近7分钟破解出密钥：e0be8d5d 70bb3140 7e983fff

```
root@labs-a3:~/blus/1027# tail -f 1.log
Generated 4194304 Z values.
[02:48:48] Z reduction using 8 bytes of known plaintext
100.0 % (8 / 8)
889179 values remaining.
[02:48:49] Attack on 889179 Z values at index 7
82.4 % (733107 / 889179)
[02:55:43] Keys
e0be8d5d 70bb3140 7e983fff

real    6m55.013s
user    164m33.940s
sys     0m13.780s
```

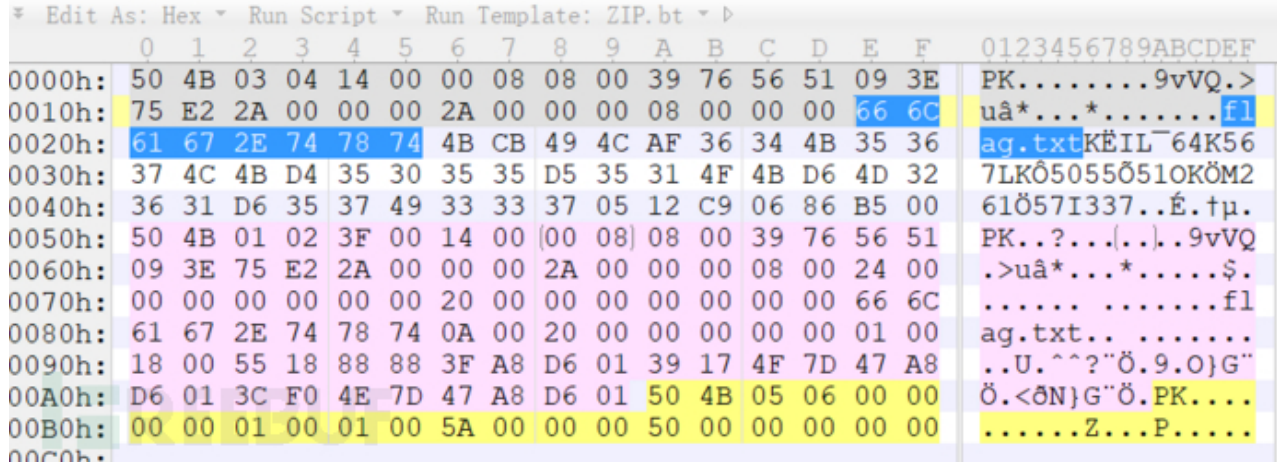
利用密钥解密文件：

bkrack -C png4.zip -c flag.txt -k e0be8d5d 70bb3140 7e983fff -d flag.txt

```
root@labs-a3:~/blus/1027# bkrack -C png4.zip -c flag.txt -k e0be8d5d 70bb3140 7e983fff -d flag.txt
Wrote deciphered text.
root@labs-a3:~/blus/1027# cat flag.txt
flag{2f09f201dc590e0ecd71a90272996666}root@labs-a3:~/blus/1027#
```

3.2.3 利用压缩包格式破解

将一个名为flag.txt的文件打包成ZIP压缩包后，你会发现文件名称会出现在压缩包文件头中，且偏移固定为30。且默认情况下，flag.zip也会作为该压缩包的名称。



所以，当一个加密压缩包中存在另一个ZIP压缩包时，且能够知道或猜测该压缩包内的文件名称时，可以尝试进行已知明文攻击。

将flag.zip与其他文件（选用一张图片）一起用好压打包成加密ZIP压缩包：test5.zip

名称	算法	大小	压缩后大小
2.png	ZipCrypto Deflate	2 409 786	2 404 831
flag.zip	ZipCrypto Store	192	204

已知的明文片段有：

- “flag.txt” 8个字节， 偏移30
- ZIP本身文件头：50 4B 03 04 ， 4字节

8+4，满足了破解的最低要求

攻击:

echo -n "flag.txt" > plain1.txt // -n参数避免换行，不然文件中会出现换行符，导致攻击失效

time bkrack -C test5.zip -c flag.zip -p plain1.txt -o 30 -x 0 504B0304 >1.log&

tail -f 1.log

得到密钥：

b21e5df4 ab9a9430 8c336475

```
root@labs-a3:~/blus/1026/test2# tail -f 1.log
Generated 4194304 Z values.
[23:17:41] Attack on 4194304 Z values at index 37
79.4 % (3331264 / 4194304)
[23:51:24] Keys
b21e5df4 ab9a9430 8c336475

real    33m43.071s
user    772m4.320s
sys     0m58.340s
```

利用密钥解密：

bkrack -C test5.zip -c flag.zip -k b21e5df4 ab9a9430 8c336475 -d flag.zip

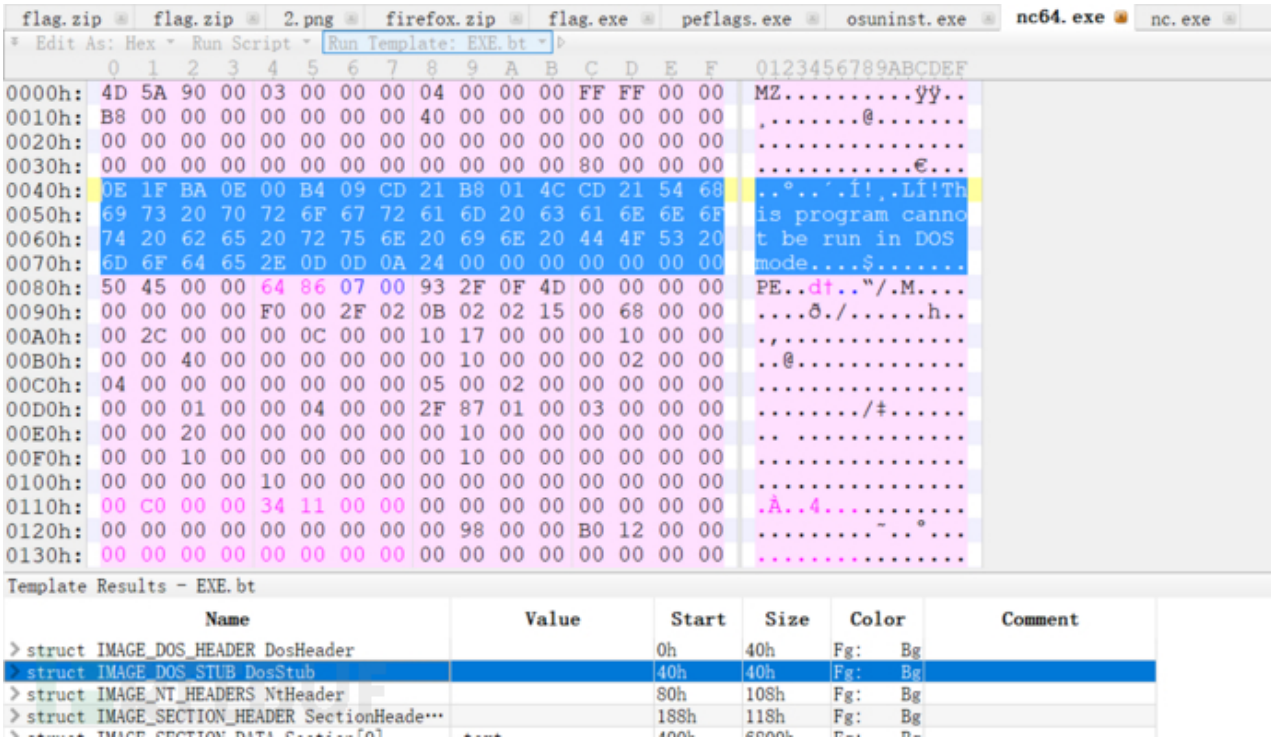
flag.zip可以直接成功解密。

但若想解密2.png，由于是ZipCrypto deflate加密的，所以解密后需要bkrack/tool内的inflate.py脚本再次处理。

3.2.4 EXE文件格式破解

EXE文件默认加密情况下，不太会以store方式被加密，但它文件格式中的的明文及其明显，长度足够。如果加密ZIP压缩包出现以store算法存储的EXE格式文件，很容易进行破解。

大部分exe中都有这相同一段，且偏移固定为64：



生成一个加密EXE的ZIP压缩包进行测试：nc64.zip

名称	算法	大小	压缩后大小
nc64.exe	ZipCrypto Store	45 272	45 284

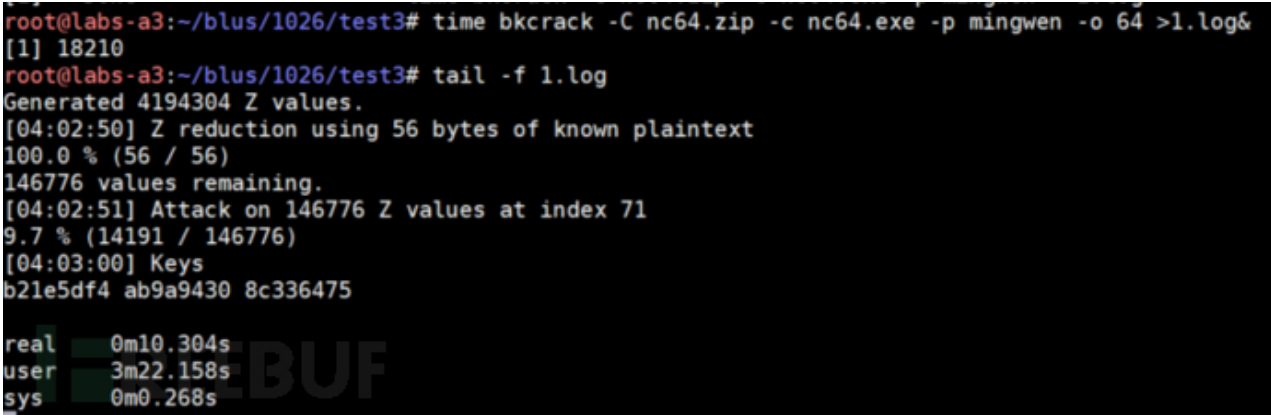
攻击破解：

```
#准备明文
echo -n
"0E1FBA0E00B409CD21B8014CCD21546869732070726F6772616D2063616E6E6F742062652072756E
20696E20444F53206D6F64652E0D0D0A2400000000000000" | xxd -r -ps > mingwen

#攻击
time bkrack -C nc64.zip -c nc64.exe -p mingwen -o64 >1.log&

#查看进度
tail -f 1.log
```

很快就解出了密钥：



b21e5df4 ab9a9430 8c336475

解密：

bkrack -C nc64.zip -c nc64.exe -k b21e5df4 ab9a9430 8c336475 -d nc64.exe

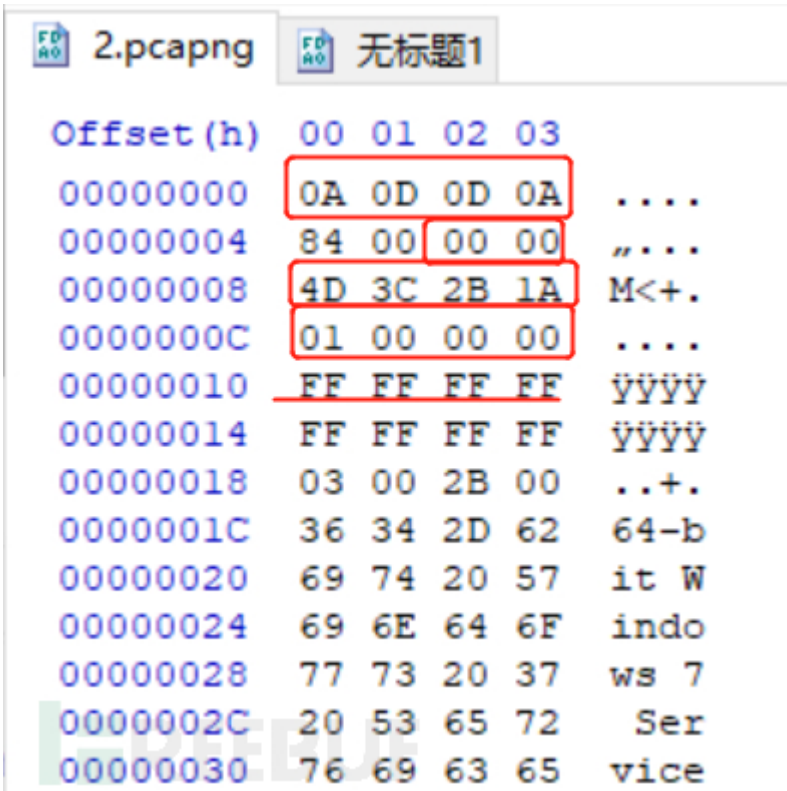
3.2.5 流量包pcapng格式解密

这个有例题：钓鱼城杯-量子加密

具体格式介绍及解法参考官方的writeup,已打包在附件中

名称	算法	大小	压缩后大小
capture.pcapng	Store	886 316	886 328
hint_for_capture.txt	Store	36	48

加密算法都是 Store



网络安全

99+

7

攻击:

```
echo -n "00004D3C2B1A01000000FFFFFFFFFFFFFFFF" | xxd -r -ps > pcap_plain1
```

```
time bkrack -C 3.zip -c capture.pcapng -p pcap_plain1 -o 6
```

```
root@labs-a3:~/blus# time bkrack -C 3.zip -c capture.pcapng -p pcap_plain1 -o 6
Generated 4194304 Z values.
[04:26:26] Z reduction using 10 bytes of known plaintext
100.0 % (10 / 10)
642004 values remaining.
[04:26:27] Attack on 642004 Z values at index 13
79.1 % (507594 / 642004)
[04:31:17] Keys
e33a580c c0c96a81 1246d892

real    4m50.327s
user    115m5.465s
sys     0m7.134s
```

解密:

```
bkrack -C 3.zip -c capture.pcapng -k e33a580c c0c96a81 1246d892 -d out.pcapng
```

3.2.6 网站相关文件破解

网站目录中充斥着大量类型的文件，哪怕被打包成加密ZIP，也很容易找到突破口。

例如:

robots.txt的文件开头内容通常是User-agent: *

html文件开头通常是 <!DOCTYPE html>

xml文件开头通常是<?xml version="1.0" encoding="UTF-8"?>

在此以web.xml为例，web.xml 是网络程序中的一个很重要的配置文件。

常见xml文件头为:

```
<?xml version="1.0" encoding="UTF-8"?>
```

网站目录肯定会涉及到多级目录，我们也同样进行模拟。在文件夹中创建一个二级目录“123”，并将一个web.xml放入该二级目录中，然后打包成加密ZIP。

名称	算法	大小	压缩后大小	修
web.xml	ZipCrypto Store	959	971	20

攻击:

```
echo -n '<?xml version="1.0" encoding="UTF-8"?>' > xml_plain
```

```
time bkrack -C xml.zip -c 123/web.xml -p xml_plain -o 0 //注意相对路径
```

攻击成功:

```
root@labs-a3:~/blus/1027-2# time bkrack -C xml.zip -c 123/web.xml -p xml_plain -o 0
Generated 4194304 Z values.
[05:34:47] Z reduction using 30 bytes of known plaintext
100.0 % (30 / 30)
254534 values remaining.
[05:34:48] Attack on 254534 Z values at index 7
86.8 % (220866 / 254534)
[05:36:53] Keys
e0be8d5d 70bb3140 7e983fff

real    2m6.274s
user    49m37.895s
sys     0m3.059s
```

解密:

```
bkrack -C xml.zip -c 123/web.xml -k e0be8d5d 70bb3140 7e983fff -d web.xml
```

3.2.7 SVG文件格式破解

xml格式的文件除了.xml以外，也包括.svg文件。SVG是一种基于XML的图像文件格式。

名称	大小	CRC	算法
advice.jpg	54 799	7CA9F10A	ZipCrypto Deflate
spiral.svg	1 265	A99F1D0D	ZipCrypto Store

攻击:

//已知明文

```
echo -n '<?xml version="1.0" ' > plain.txt
```

```
bkrack -C secrets.zip -c spiral.svg -p plain.txt -o 0
```

攻击成功:

```
root@labs-a3:~/blus/1028# echo -n '<?xml version="1.0" ' > plain.txt
root@labs-a3:~/blus/1028# bkrack -C secrets.zip -c spiral.svg -p plain.txt -o 0
Generated 4194304 Z values.
[23:17:22] Z reduction using 12 bytes of known plaintext
100.0 % (12 / 12)
549421 values remaining.
[23:17:23] Attack on 549421 Z values at index 7
29.2 % (160370 / 549421)
[23:18:51] Keys
```

网络安全

99+

7

//解密 Store算法 直接解密即可

```
bkcrack -C secrets.zip -c spiral.svg -k c4038591 d5ff449d d3b0c696 -d spiral_deciphered.svg
```

//解密 deflate算法

```
bkcrack -C secrets.zip -c advice.jpg -k c4038591 d5ff449d d3b0c696 -d advice.deflate
```

//该文件使用了deflate算法压缩的，解码出来的是Deflate的数据流,因此须将其解压缩。

```
python3 inflate.py < advice.deflate > advice.jpg
```

四、结尾

4.1 结语

以上这些案例只是给打击做个示范，打开大家的思路，实际可用的场景有许多。例如一些CTF题目压缩包的非预期解，或者网络上资源的破解。

4.2 注意点

已知的明文长度越长，破解速度越快
图片、文本格式文件、压缩包是最容易以store算法被加密打包的
有时会出现攻击得到了密钥，却无法解密正确文件的情况
存在rbkcrack项目，增加了部分支持

4.3 附件下载

链接：<https://pan.baidu.com/s/1fuuHYFHsU2e0elAjO7FLfw>
提取码：t2y4

4.4 参考文章

https://www.aloxaf.com/2018/10/zip_crack/
<https://zhuanlan.zhihu.com/p/129855130>

本文作者：光通天下无患实验室 BlusKing

本文作者：光通天下， 转载请注明来自FreeBuf.COM

网络安全技术

被以下专辑收录，发现更多精彩内容

- + 收入我的专辑
- + 加入我的收藏
- 网络安全知识大合集
- 学习
- CTF
- 信息安全

评论 7

按热度排序

- dc198488 LV.1

(这家伙太懒了，还未填写个人描述!)

问题：文件名是中文怎么办？

2021-09-24 21:01:52

亮了 回复
- 离散的时空 LV.1

来自新浪微博

回复@狼野山金:winrar和7zip加密的不行

2020-12-08 14:36:13

亮了 回复
- 僵尸网络

12个字节，那不是多尝试一下就能试出来

2020-12-08 14:06:12

亮了 回复
- Eric_退堂鼓济南分鼓 LV.1

来自新浪微博

回复@狼野山金:我个人理解，安全是个相对概念，取决于你这个压缩文件存的东西的重要性和破解需要的时间成本。

2020-12-08 11:50:54

亮了 (1) 回复
- 狼野山金 LV.1

来自新浪微博

问题是，大部分人认为很安全

2020-12-08 11:29:56

亮了 (1) 回复
- GHOST

害，我以为的安全都不安全了

2020-12-08 10:36:20

亮了 (1) 回复

网络安全

99+

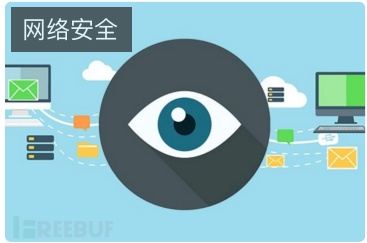
7



请 [登录](#) / [注册](#) 后在FreeBuf发布内容哦

相关推荐

pretender：一款功能强大的红队MitM安全测试工具



pretender是一款功能强大的红队MitM安全测试工具，专为红队研究人员设计。

 Alpha_h4ck
 已有 2699 人围观
 2022-09-09

多种技巧打靶HTB_Talkative 金币



一、信息收集1.端口扫描使用nmap进行扫描找到五个打开的 TCP 端口。有一个 Apache (80)，三个 Tornado (8080、8...

 pony686 NIP
 已有 38390 人围观
 2022-09-07

VnInHub CHRONOS 1 原创

Web安全



涉及知识包括：端口服务探测、解编码、命令注入、nc串联、linux本地提权、框架漏洞利用等

 xiaopanghacker
 已有 7892 人围观
 2022-09-03

VnInHub BORED HACKER BLOG CLOUD AV 原创

Web安全



涉及知识包括：端口服务探测、sql注入、命令注入、nc串联、python反弹shell、密码爆破、linux本地提权等

 xiaopanghacker
 已有 6337 人围观
 2022-09-03

如何将VirtualBox虚拟机转换到VMware中 原创

工具



将VirtualBox虚拟机转换为VMware虚拟机，在VMware中运行。

 xiaopanghacker
 已有 4371 人围观
 2022-09-02

